

Informe Técnico de Evaluación de Seguridad

Marca de Agua: Auditoría de Seguridad – SafeStart App Simulada

Consultor de Seguridad: Bastian Landskron

Fecha: 03/07/2025

Diagnóstico de Seguridad Actual

La aplicación interna de SafeStart fue evaluada desde la perspectiva de autenticación, autorización, sesiones, criptografía y cumplimiento con las recomendaciones OWASP. Se detectaron vulnerabilidades críticas que exponen tanto la confidencialidad de los datos como la integridad del sistema. Entre los hallazgos más relevantes destacan el almacenamiento inseguro de contraseñas, la ausencia de mecanismos de autorización, la inexistencia de control sobre las sesiones y la exposición directa de información sensible.

La implementación actual del sistema de login es básica e insuficiente. Las credenciales se almacenan en texto plano, sin ninguna forma de cifrado o hash, y el proceso de autenticación carece de protección contra intentos automatizados o acceso indebido. Además, todos los usuarios tienen el mismo nivel de acceso, lo cual representa una violación directa a los principios de mínimo privilegio y separación de funciones.

En cuanto al manejo de sesiones, la aplicación no implementa ningún tipo de control o expiración de sesión, no utiliza cookies seguras, ni protege los tokens de acceso, lo que facilita ataques como el secuestro de sesión. Finalmente, el sistema carece de cualquier tipo de monitoreo o registro de actividades sospechosas, lo cual impide la detección temprana de accesos no autorizados.

Propuesta de Mejora

Se recomienda rediseñar completamente el flujo de autenticación, aplicando prácticas modernas como el uso de tokens firmados (JWT), el hash seguro de contraseñas mediante algoritmos como bcrypt y la incorporación de autenticación multifactor (2FA). La simple verificación por usuario y contraseña debe ser fortalecida con una capa adicional de seguridad para reducir el riesgo de ataques por fuerza bruta o reutilización de credenciales.

Para controlar el acceso, se propone la implementación de un modelo de control basado en roles (RBAC), el cual permitirá definir distintos niveles de privilegio y limitar el acceso a funcionalidades sensibles dependiendo del perfil del usuario. Esto incluye separar claramente las responsabilidades entre administradores, personal de recursos humanos y usuarios visitantes.

En cuanto a la gestión de sesiones, se sugiere el uso de tokens con expiración automática, la regeneración periódica de los mismos y la configuración de cookies seguras ([HttpOnly](#), [Secure](#), [SameSite](#)). Estas medidas reducen significativamente el riesgo de secuestro de

sesión, acceso desde scripts maliciosos y transmisión de credenciales a través de canales inseguros.

A nivel criptográfico, se debe abandonar por completo el almacenamiento en texto plano. Las contraseñas deben ser hasheadas con algoritmos robustos, y los datos sensibles que se necesiten cifrar deben usar estándares como AES o RSA, según el caso. Es importante distinguir claramente entre hashing (operación unidireccional, ideal para credenciales) y cifrado (reversible, útil para tokens o archivos).

Análisis de Vulnerabilidades OWASP

De acuerdo al análisis realizado, se identificaron tres vulnerabilidades que se alinean con las más críticas del OWASP Top 10:

1. **Broken Authentication:** La falta de verificación adecuada del usuario, la ausencia de cifrado en las contraseñas y la inexistencia de control sobre la sesión permiten a un atacante suplantar identidades fácilmente.
2. **Broken Access Control:** Todos los usuarios tienen acceso irrestricto al mismo panel, sin importar su rol o nivel de privilegio. Esto permite realizar acciones para las cuales no están autorizados.
3. **Sensitive Data Exposure:** La información crítica como contraseñas y sesiones se transmite y almacena sin protección, quedando vulnerable a interceptación, manipulación o robo.

Para mitigar estas amenazas, se recomienda la implementación inmediata de técnicas modernas de autenticación segura, cifrado de datos en tránsito y en reposo, validación estricta de privilegios por usuario y protección activa contra ataques automatizados.

Herramientas de Evaluación

Se utilizó **OWASP ZAP** como herramienta principal para la auditoría automática de seguridad de la aplicación. Esta permitió identificar formularios no protegidos, falta de validación en puntos de entrada de datos y respuestas del servidor que exponen información sensible. La herramienta también facilitó la simulación de ataques comunes como inyección de scripts (XSS), inclusión de SQL maliciosas e intento de acceso no autorizado.

OWASP ZAP resultó clave no solo para el descubrimiento de vulnerabilidades, sino también como mecanismo de validación posterior, al verificar que las mejoras propuestas reducen efectivamente la superficie de ataque.

Conclusiones Técnicas

La aplicación actual de SafeStart se encuentra en un estado de seguridad crítico. Las fallas detectadas en la autenticación, control de acceso y manejo de datos sensibles la hacen vulnerable ante ataques básicos que podrían comprometer tanto la información interna como la reputación institucional. Se ha propuesto un plan de mejora integral, alineado con estándares internacionales y buenas prácticas del desarrollo seguro, que cubre desde el diseño del sistema de login hasta la gestión criptográfica y de sesiones.

Implementar estas recomendaciones no solo fortalece la postura de seguridad técnica de la aplicación, sino que también establece una base confiable para su crecimiento futuro y el cumplimiento normativo.

Reflexión Ética y Profesional

Proteger las funciones básicas como el login, la asignación de roles y la gestión de sesiones no es solo una buena práctica técnica, sino una responsabilidad ética. La mala gestión de sesiones puede dar lugar a accesos indebidos, robo de información y daños graves para la organización y los usuarios. A lo largo del análisis se tomaron decisiones que reflejan un compromiso con la privacidad, la integridad de los sistemas y la profesionalización del desarrollo seguro. Este ejercicio reafirma que la ciberseguridad no es un añadido, sino una condición fundamental desde las primeras líneas de código.